# Guía para principiantes · Hablar con una API usando Postman

> Esta guía es para alguien que **empieza en tecnología**. No necesitas saber programar.
> Vamos a dar **8 pasos cortos**, y en cada uno te explico **qué hacemos y por qué**.
> Tardarás unos 25 minutos.
> Usaremos la **VulnBank API** en su versión **endurecida** (la segura). El banco es inventado: el dinero y las personas son ficticios, así que no puedes romper nada.

## Primero, 4 ideas básicas

**1. ¿Qué es una API?** Piensa en un restaurante. Tú (el cliente) no entras a la cocina: le pides las cosas al **camarero**, y él te trae lo que pediste. Una **API** es ese camarero: un programa al que le pides datos ("¿cuánto dinero tengo?") y te responde.

**2. ¿Qué es Postman?** Es un programa gratuito para **hacerle pedidos a una API** sin escribir comandos: rellenas casillas y pulsas un botón. Es como un formulario para hablar con el camarero.

**3. ¿Qué es un token?** Es como la **pulsera de un concierto**: cuando demuestras quién eres (con tu usuario y contraseña) te dan una pulsera. Después, en cada pedido, enseñas la pulsera y ya no tienes que volver a dar la contraseña. La pulsera **caduca a los 15 minutos**.

**4. ¿Qué es JSON?** Es la forma en que la API escribe sus respuestas: una lista ordenada de **nombre: valor**, entre llaves `{ }`. Por ejemplo:

```
{ "nombre": "Laura", "saldo": 2450.75 }
```

## Conoce la pantalla de Postman

Cuando abras un pedido nuevo verás estas zonas (de arriba abajo):

| Zona | Para qué sirve |
|---|---|
| **Método** (desplegable a la izquierda, dice `GET`) | El tipo de pedido: `GET` = **pedir** datos, `POST` = **enviar** datos. |
| **Barra de dirección** (al lado del método) | A qué dirección le haces el pedido. |
| Botón azul **Send** | Envía el pedido. |
| Pestaña **Headers** | Información extra que acompaña al pedido (aquí irá la pulsera). |
| Pestaña **Body** | Los datos que envías (usuario, contraseña, importe…). |
| Panel de abajo, **Response** | La respuesta de la API. Arriba a la derecha verás el **código**: `200 OK`, `404 Not Found`… |

> **El código de respuesta** es un número que resume qué pasó: `200` = todo bien; `400` = enviaste algo incorrecto; `401` = no te identificaste; `404` = no existe (o no es tuyo). Postman lo muestra en verde si salió bien y en rojo si no.

## Paso 1 · Instalar y abrir Postman

1. Entra en **postman.com/downloads**, descarga la versión para tu ordenador (Mac o Windows) e instálala como cualquier programa.
2. Ábrela. Te pedirá **crear una cuenta gratuita** (o iniciar sesión con Google). Hazlo: es gratis.
3. Si te pregunta a qué te dedicas o qué quieres hacer, puedes saltarlo.

> Usa la **aplicación de escritorio**, no la versión web: la web necesita instalar un complemento extra para funcionar.

## Paso 2 · Guardar la dirección de la API

La API vive en una dirección de Internet, como una página web. Como es larga, la guardamos con un nombre corto, **`api`**, igual que guardas un contacto en el móvil para no escribir el número cada vez. En Postman esto se hace con un **Environment** (entorno): una libreta de datos guardados.

1. En la barra de la izquierda, pulsa **Environments**.
2. Pulsa el **+** para crear uno nuevo y ponle de nombre `VulnBank`.
3. En la tabla, en la primera fila escribe:
4. Columna **Variable**: `api`
5. Columna de **valor** (si ves dos columnas de valor, en las dos): `https://yellow-ground-024d78310.6.azurestaticapps.net/api/lab`

6. En la segunda fila escribe la variable `token` y deja el valor **vacío** (lo rellenaremos en el paso 5).
7. Guarda con **Cmd + S** (Mac) o **Ctrl + S** (Windows).
8. Arriba a la derecha hay un desplegable que dice **No environment**: elige **VulnBank**. ¡Importante! Si no lo eliges, Postman no conoce `api`.

A partir de ahora, escribir `{{api}}` en Postman es lo mismo que escribir la dirección completa. Las dobles llaves `{{ }}` significan: *"usa el valor guardado con este nombre"*.

## Paso 3 · Saludar a la API

Vamos a hacer el pedido más sencillo: preguntarle qué versión es.

1. Pulsa el **+** de las pestañas de arriba para abrir un pedido nuevo.
2. Deja el método en **GET** (vamos a **pedir** datos).
3. En la barra de dirección escribe:

```
{{api}}/version
```

4. Pulsa **Send**.

**Respuesta** (abajo, código `200 OK`):

```
{
  "lab": "VulnBank API",
  "version": "endurecida"
}
```

Si ves esto, **ya hablaste con una API**. Si dice `"vulnerable"`, la versión segura no está puesta (pídele a Claude: *"coloca el laboratorio de API endurecida"*).

> Si `{{api}}` sale en **rojo**, Postman no la reconoce: revisa que elegiste el environment **VulnBank** arriba a la derecha (paso 2, punto 6).

## Paso 4 · Iniciar sesión (conseguir la pulsera)

Ahora le decimos a la API quiénes somos. Somos **Laura** y su contraseña es `Laura2026!`.

1. Abre un pedido nuevo con el **+**.
2. Cambia el método a **POST** (vamos a **enviar** datos).
3. Dirección:

```
{{api}}/auth/login
```

4. Ve a la pestaña **Body**, marca **raw** y, en el desplegable que aparece a la derecha (dice `Text`), elige **JSON**.
5. Pega en el cuadro de texto:

```
{
  "username": "laura",
  "password": "Laura2026!"
}
```

6. Pulsa **Send**.

**Qué hicimos:** con **POST** le enviamos a la ventanilla de inicio de sesión (`/auth/login`) un JSON con usuario y contraseña. Al elegir **JSON**, Postman avisa solo a la API de que le mandamos JSON.

**Respuesta (resumida, código `200 OK`):**

```
{
  "token": "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJzdWIiOjEwMDEs...",
  "expiresIn": 900,
  "user": { "username": "laura", "fullName": "Laura Gómez", ... }
}
```

El texto largo que empieza por `eyJ` es tu **token** (tu pulsera). `"expiresIn": 900` significa que dura 900 segundos = 15 minutos.

## Paso 5 · Guardar el token

Para no pegarlo en cada pedido, lo guardamos en la libreta **VulnBank**:

1. En la respuesta, selecciona **solo el texto del token** (desde `eyJ` hasta antes de las comillas finales) y cópialo (**Cmd + C** / **Ctrl + C**).
2. Ve a **Environments → VulnBank**.
3. En la fila `token`, pega el token en la columna de valor (si hay dos columnas, en las dos).
4. Guarda con **Cmd + S** / **Ctrl + S**.

> **Atajo:** también puedes seleccionar el token en la respuesta, pulsar el botón derecho del ratón y elegir **Set: VulnBank → token**.

## Paso 6 · Ver mis datos y mi dinero

Ahora enseñamos la pulsera en cada pedido. Se hace añadiendo una **cabecera** (header) llamada `X-Auth-Token`, que significa: *"esta es mi pulsera"*.

**Mi perfil:**

1. Pedido nuevo (**+**), método **GET**, dirección:

```
{{api}}/users/me
```

2. Pestaña **Headers**. En la primera fila vacía escribe:

| Key | Value |
|---|---|
| `X-Auth-Token` | `{{token}}` |

3. Pulsa **Send**.

Verás tu nombre, email y teléfono. Fíjate en lo que **no** aparece: ni la contraseña ni el DNI. La API segura **solo enseña lo necesario**.

**Mi cuenta y saldo** (la cuenta de Laura es la **5001**): en el **mismo** pedido, cambia solo la dirección y pulsa **Send** (la cabecera se queda puesta):

```
{{api}}/accounts/5001
```

```
{ "id": 5001, "iban": "ES00 0000 0000 0000 0000 5001", "balance": 2450.75, "currency": "EUR", ... }
```

`balance` es el saldo: **2450,75 €**.

## Paso 7 · Enviar dinero a Carlos

Vamos a transferir **10 €** de la cuenta de Laura (5001) a la de Carlos (5002):

1. Pedido nuevo (**+**), método **POST**, dirección:

```
{{api}}/transfers
```

2. Pestaña **Headers**: añade otra vez `X-Auth-Token` = `{{token}}`.
3. Pestaña **Body** → **raw** → **JSON**, y pega:

```
{
  "fromAccountId": 5001,
  "toAccountId": 5002,
  "amount": 10
}
```

4. Pulsa **Send**.

Los datos dicen: desde la cuenta **5001**, a la **5002**, **10** euros.

**Respuesta (código `200 OK`):**

```
{ "ok": true, "from": { "id": 5001, "balance": 2440.75 }, "to": { "id": 5002 } }
```

`"ok": true` = la transferencia salió bien, y ahora tienes **2440,75 €**.

## Paso 8 · Intentar hacer trampa (y ver cómo la API se defiende)

Una API segura **comprueba todo** antes de obedecer. Probemos tres trampas:

**Trampa 1 · Mirar la cuenta de otra persona.** Vuelve al pedido del paso 6, cambia la dirección a la cuenta de Carlos y pulsa **Send**:

```
{{api}}/accounts/5002
```

Código `404 Not Found`:

```
{ "error": "Cuenta no encontrada" }
```

**Por qué:** la API revisa que la cuenta sea **tuya**. Como no lo es, responde como si no existiera (así ni siquiera revela que existe).

**Trampa 2 · Enviar dinero "negativo".** Si mandas **−1000 €** a Carlos, en un sistema mal hecho eso le **quitaría** 1000 € a él y te los daría a ti. En el pedido del paso 7, cambia el `amount` y pulsa **Send**:

```
{
  "fromAccountId": 5001,
  "toAccountId": 5002,
  "amount": -1000
}
```

Código `400 Bad Request`:

```
{ "error": "amount debe ser un número positivo con máximo 2 decimales" }
```

**Por qué:** la API comprueba que el importe sea positivo y que tengas saldo.

**Trampa 3 · Pedir datos sin pulsera.** Vuelve al pedido del paso 6, pon la dirección `{{api}}/users/me` y, en **Headers**, **desmarca la casilla** que hay a la izquierda de `X-Auth-Token` (así no se envía). Pulsa **Send**.

Código `401 Unauthorized`:

```
{ "error": "Falta un token válido (cabecera X-Auth-Token)" }
```

**Por qué:** sin identificarte, la API no te da información privada. (Vuelve a marcar la casilla para seguir usándola.)

> **Esta es la idea principal de la seguridad en APIs:** la API **nunca debe confiar** en lo que le pide el cliente. Debe comprobar **quién eres**, **si lo que pides es tuyo** y **si los datos tienen sentido**. En la versión vulnerable del laboratorio, estas tres trampas **sí funcionan**.

## Para terminar · Dejar todo como al principio

Esto devuelve los saldos a sus valores iniciales, para la siguiente persona. Pedido nuevo, método **POST**, sin Body ni Headers:

```
{{api}}/reset
```

```
{ "ok": true, "message": "Datos del laboratorio restaurados" }
```

> **Consejo:** guarda tus pedidos con **Cmd + S** / **Ctrl + S** dentro de una colección (por ejemplo, "VulnBank") para no tener que crearlos otra vez.

## Si algo sale mal

| Ves esto | Qué pasa | Qué hacer |
|---|---|---|
| `{{api}}` en rojo, o `Could not send request` / `Invalid URL` | No está elegido el environment **VulnBank**. | Elígelo arriba a la derecha (paso 2, punto 6). |
| `401` · `Falta un token válido` | La pulsera caducó (15 min), no la guardaste o falta la cabecera. | Repite los pasos 4 y 5 y revisa la pestaña **Headers**. |
| `401` aunque usaste la pestaña **Authorization** → *Bearer Token* | Esta API no usa esa pestaña: el servidor (Azure) la reserva para su propio uso. | Pon el token en **Headers** como `X-Auth-Token`. |
| `401` · `Credenciales inválidas` | Usuario o contraseña mal escritos. | Copia el JSON del paso 4 tal cual. |
| `400` · `El cuerpo debe ser un objeto JSON válido` | En **Body** no está elegido **raw → JSON**, o falta una coma o comilla. | Revisa el paso 4, punto 4, y pega el JSON otra vez. |
| `429` · `Demasiados intentos` | Fallaste la contraseña 5 veces: la API te bloquea (¡es una defensa!). | Haz el pedido de "Para terminar" y vuelve al paso 4. |
| `Could not get response` | No hay Internet o la dirección está mal escrita. | Revisa la conexión y el valor de `api` en el paso 2. |

# Mini-diccionario

| Palabra | Qué significa |
|---|---|
| **API** | Programa que recibe pedidos y devuelve datos (el camarero). |
| **Postman** | Programa para hacerle pedidos a una API rellenando casillas. |
| **GET** | Pedir datos. |
| **POST** | Enviar datos, por ejemplo para iniciar sesión o transferir. |
| **Token** | Tu "pulsera" para demostrar quién eres en cada pedido. Caduca. |
| **JSON** | Formato de las respuestas: `{ "nombre": valor }`. |
| **Endpoint** | Cada "ventanilla" de la API, como `/version` o `/accounts/5001`. |
| **Header** (cabecera) | Información extra que acompaña al pedido, como la pulsera. |
| **Body** (cuerpo) | Los datos que envías en un pedido POST. |
| **Environment** | Libreta de Postman donde guardas datos con nombre ( `api` , `token` ). |
| `{{nombre}}` | En Postman: "usa el valor guardado con este nombre". |
| **Código de respuesta** | Número que resume qué pasó: 200 bien, 400 datos mal, 401 sin identificar, 404 no existe. |

# Anexo · Colección lista para importar (opcional)

Si ya entendiste los pasos y quieres **ahorrar tiempo**, existe un archivo con todos los pedidos de esta guía ya preparados: `VulnBank-API-endurecida.postman_collection.json`.

1. En Postman pulsa **Import** (arriba a la izquierda).
2. Arrastra el archivo a la ventana.
3. Aparece la colección **VulnBank API (endurecida)** a la izquierda, con los pedidos numerados como en esta guía.
4. Ejecuta **"4 · Iniciar sesión"**: en esta colección el token **se guarda solo**, no hace falta el paso 5.

> La colección ya trae la dirección de la API. Si tienes elegido el environment **VulnBank**, se usan sus valores; si no, los de la colección. Las dos formas funcionan.